漏洞测试实验报告（Easy File Sharing Web Server 远程溢出漏洞）

一、实验目的

1. 掌握使用 Nmap 对目标主机进行端口扫描、服务识别的操作方法，从扫描结果判断目标开放的服务及版本。
2. 掌握使用 Kali 自带的 exploit-db 漏洞库与 searchsploit 命令检索公开漏洞利用模块的方法。
3. 理解远程缓冲区溢出漏洞的成因，通过运行 Python 编写的 exploit 脚本，成功复现 Easy File Sharing Web Server 的远程溢出漏洞。
4. 复现课本 P170 7.4 内容，掌握 Metasploit 框架的基础使用方法

二、实验环境

- 攻击机：Kali Linux（IP 192.168.209.161），自带 exploit-db 漏洞库
- 目标靶机：Windows（IP 192.168.209.199），安装 Easy File Sharing Web Server，Web 服务监听 80 端口
- 工具：Nmap、searchsploit、exploit-db 中的 Python 脚本、浏览器

三、实验原理

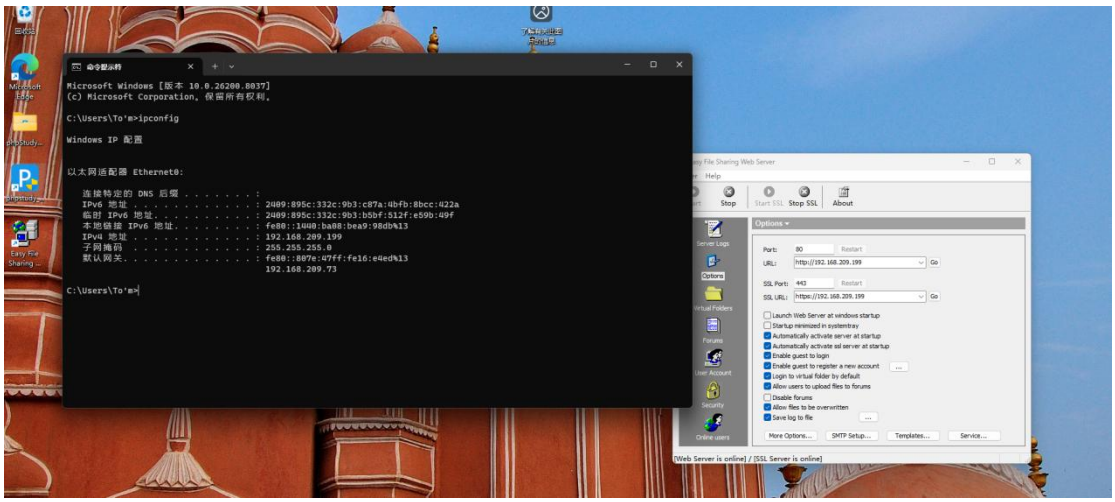
1. **漏洞成因**：Easy File Sharing Web Server 在处理 HTTP 请求（如上传目录、路径等参数）时，未对输入长度进行边界检查，造成缓冲区溢出；溢出后覆盖返回地址或 SEH 异常处理链，攻击者可控制程序执行流程，实现远程代码执行。
2. **信息收集**：Nmap 通过端口扫描探测开放端口并识别服务横幅（banner），从而确认目标运行的是 Easy File Sharing Web Server httpd 6.9，服务版本就是判断是否存在已知漏洞的关键依据。
3. **漏洞检索**：searchsploit 是在本地 exploit-db 漏洞库中按关键字检索，能快速找到该软件对应的公开 exploit 脚本路径与编号。
4. **漏洞利用**：直接运行检索到的 Python exploit 脚本，传入目标 IP 与端口，脚本构造超长恶意请求发送至目标，触发溢出，从而验证漏洞真实存在。

四、实验步骤

（1）Easy File Sharing Web Server 漏洞复现

步骤 1：搭建并确认目标环境

1. 在 Windows 靶机安装 Easy File Sharing Web Server，启动服务，确认 Web Server 状态为 running，监听端口 80。
2. 靶机 IP 记为 192.168.209.199

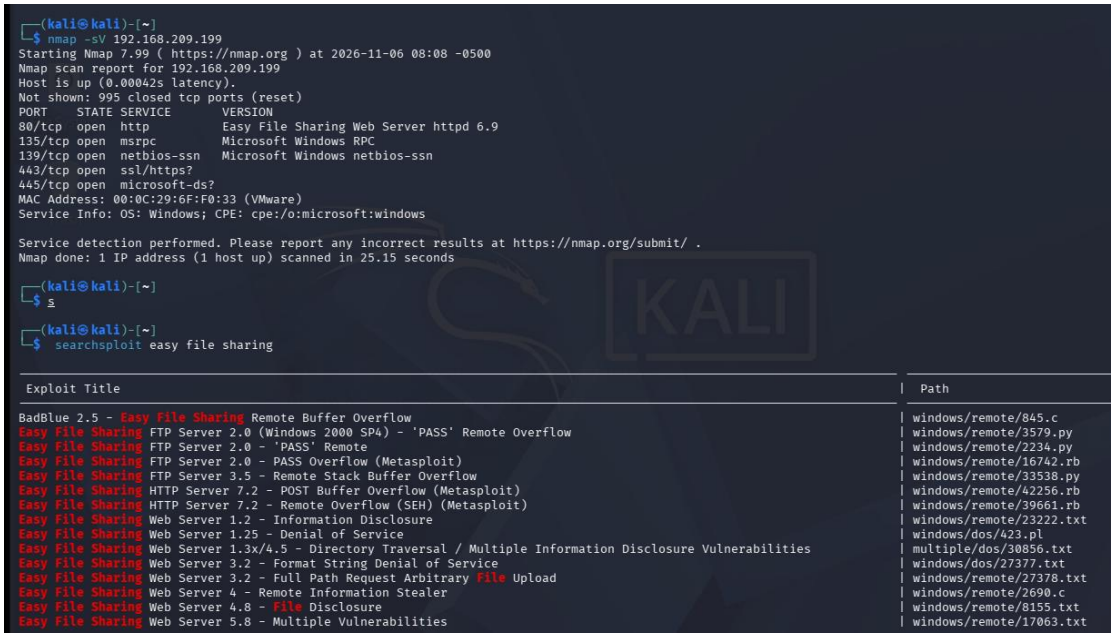


步骤 2：Nmap 扫描识别目标服务

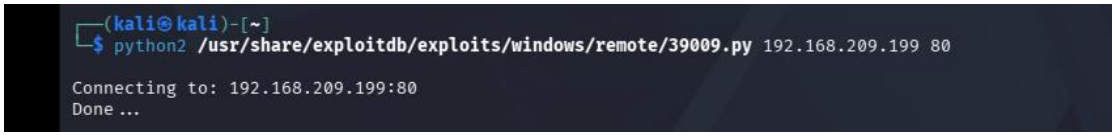
1. 在 Kali 终端执行： nmap -sV 192.168.209.199
2. 扫描结果：确认靶机开放端口和 Easy File Sharing Web Server 版本

步骤 3：searchsploit 检索对应漏洞

1. 执行命令： searchsploit easy file sharing
2. 检索结果列出多条可利用漏洞
3. 选取与目标版本对应的远程溢出模块



步骤 4：执行 exploit 脚本实施攻击



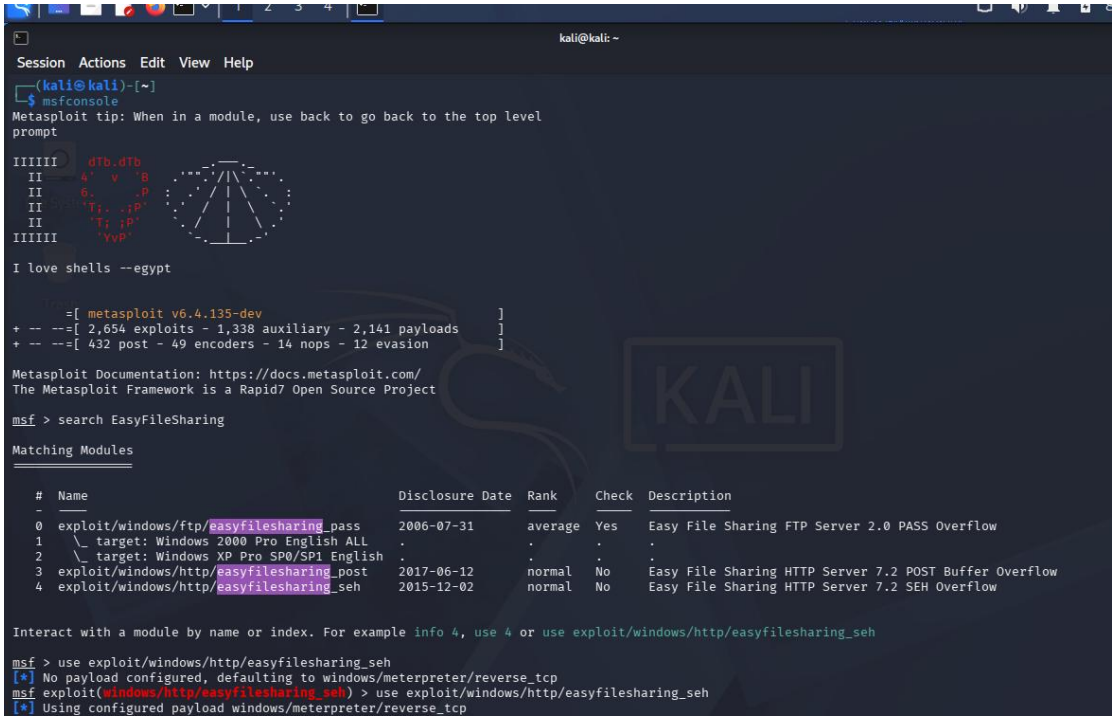
说明恶意请求已成功发送到目标，溢出被触发，漏洞无法被程本身阻挡，验证该远程溢出漏洞真实可利用。

（2）课本 p170 7.4 使用 metasploit 对软件发起攻击

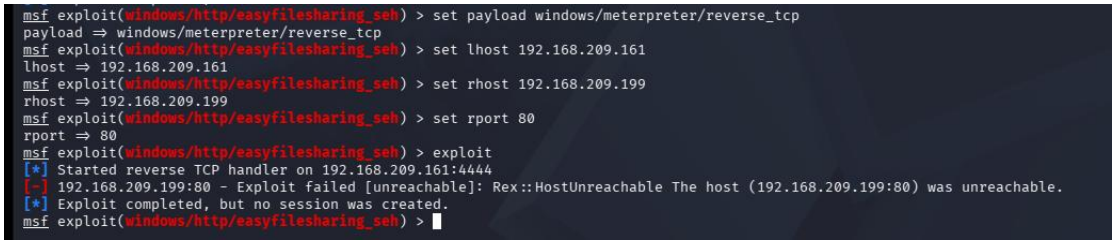
1.启动 Metasploit 在 Kali 终端输入命令，打开 msf 控制台：

2.搜索漏洞模块 使用 search 命令查找 EasyFileSharing 相关漏洞模块：

3.加载漏洞模块 选用找到的漏洞利用模块：



4.设置参数，发起攻击执行 run 命令，Metasploit 自动构造恶意请求发送给靶机，触发 SEH 缓冲区溢出。。



到此课本实验使用 metasploit 对软件发起攻击具体步骤已经复现，但由于靶机为 windows11，存在 SEHOP 防护，不是课本上 windows7 环境，没能开启对靶机的控制。

五、实验结果

1. 通过 Nmap 扫描成功发现目标主机开放 80 端口，服务为 Easy File Sharing Web Server httpd 6.9。
2. 使用 searchsploit 在本地 exploit-db 漏洞库中检索到该软件的远程溢出利用模块。
3. 执行 Python exploit 脚本后，脚本提示 `Done...`，说明恶意请求已成功发送并触发目标的缓冲区溢出，远程溢出漏洞复现成功。
4. 完整复现了课本 P170 7.4 的实验流程，并按要求保存了主要步骤截图。

六、实验总结与防护建议

安全风险：这类文件共享 Web 服务如果长期暴露并且持续使用旧版本，攻击者无需任何账号就能通过构造的超长请求远程触发溢出，进而控制服务器进程，风险等级高。

实验心得： 掌握使用 Nmap 对目标主机进行端口扫描、服务识别的操作方法，从扫描结果判断目标开放的服务及版本。

掌握使用 Kali 自带的 exploit-db 漏洞库与 searchsploit 命令检索公开漏洞利用模块的方法。

理解远程缓冲区溢出漏洞的成因，通过运行 Python 编写的 exploit 脚本，成功复现 Easy File Sharing Web Server 的远程溢出漏洞。

复现课本 P170 7.4 内容，掌握 Metasploit 框架的基础使用方法